GSC — Git Security Checker v1.4.0

SAST нового поколения: **доказывает** уязвимость, **исправляет** и **проверяет** — а не просто алертит

ЗАМКНУТЫЙ ЦИКЛ БЕЗОПАСНОСТИ

detect — 65 детекторов + LLM-ревалидация → **prove** — рабочий PoC-эксплойт запущен → **fix** — минимальный LLM-патч → **verify** — эксплойт в песочнице должен провалиться → **heal** — PR с подтверждённым фиксом

Чего нет у Semgrep / Snyk / CodeQL

	GSC	Semgrep	Snyk	CodeQL
Авто PoC-эксплойт	✓	✗	✗	✗
Верифицированный фикс	✓	✗	✗	✗
Авто-PR (self-healing)	✓	✗	✗	✗
Прогноз уязвимостей	✓	✗	✗	✗
Самообучение (авто-отключение шума)	✓	✗	✗	✗

Цифры

65 детекторов (SAST + SCA + Secrets + IaC)

12 реальных уязвимостей найдено в production-OSS

16 калибровочных проектов (9 clean + 7 vuln)

3197 тестов, 258 модулей, schema 34

Реальные находки в живой кодовой базе

- RCE — **OS Command Injection** — subprocess(shell=True) с несанитизированным вводом (VortexPanel)
 CWE-78 · исправлено upstream v3.4.14
- XSS — **innerHTML без санитизации** — пользовательский ввод в DOM (cyberbro)
 CWE-79 · PR merged
- SSRF — **ACME/HTTP-01 валидация** без проверки внутренних IP (django-ca)
 CWE-918
- SEC — **Hardcoded SECRET_KEY и API-ключи** — 5 проектов
 CWE-798 · PR merged (django-files)

Почему Яндекс

- **On-prem** — код и находки не покидают контур, Apache 2.0 для security-аудита
- **LLM-адаптер** — DeepSeek заменяется на YandexGPT без смены ядра
- **Встраивается в CI/CD** — GitHub Action, MCP-сервер, PR-комментарии, SARIF
- **Готовое ядро Proof-of-Fix** для вашего DevSecOps, а не чёрный ящик

Честные границы: Python-first (JS/TS — дорожная карта). PoC-изоляция требует контейнерного рантайма. Precision воспроизводима через gsc_meta.py — без маркетинговых процентов.

Пилот: прогоним GSC по вашему репозиторию — покажем рабочий PoC и верифицированный фикс

Apache 2.0 + Commercial · github.com/poliakarmai/gsc